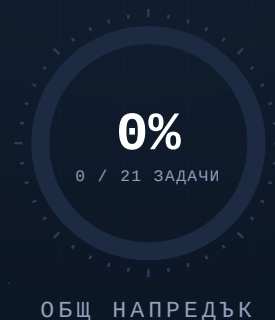




// ОПЕРАЦИЯ „ЩИТ“ · ЕТАП 01

Затягане на сигурността в Монтажи Ко ЕООД

Пет мерки с най-висок приоритет. Всяка затваря конкретна врата, през която днес може да влезе проблем. Отмятаме ги тук една по една — и виждаме как щитът се пълни.



НИВО НА ЗАЩИТА

0 / 5 МЕРКИ



00 · ЗАЩО СЕГА

Работим заедно от над 10 години и системите ви ги познавам добре — затова ще бъде директен. В момента мрежата работи, но не е защитена така, както заслужава фирма с вашия мащаб. Няма драма, няма паника — но има няколко неща, които оставени така, рано или късно ще излязат скъпо.

Подредил съм ги в етапи. **Етап 1** е тук: пет мерки, които дават най-много защита за най-малко усилие и пари. Повечето са чиста конфигурация — не изискват нов хардуер. Единственият разход е антивирусната защита, и там съм договорил добра отстъпка.

Документът е жив: всяка задача може да се отметне, когато е готова, и напредъкът се вижда веднага.



01 · МОМЕНТНА СНИМКА **Къде сме днес**

RISK-01

Админ паролите са известни на повече хора, отколкото трябва

▲ КРИТИЧНО

RISK-02

~90% от потребителите работят с администраторски права

▲ КРИТИЧНО

RISK-03

Админ конзолите на рутери и сървъри са достъпни отвън

▲ ВИСОКО

RISK-04

Сървърите работят без антивирус, компютрите — с безплатен

▲ КРИТИЧНО

RISK-05

Гости и лични телефони са в една мрежа със сървъра

▲ ВИСОКО

✓ ПОТВЪРДЕНО

— установено лично от мен при работата по системите ви.

01**Нови администраторски пароли навсякъде**

СЪРВЪРИ • РУТЕРИ • NAS • WIFI ТОЧКИ

ПРЕДСТОИ

ЗАЩО

В момента админ паролите за сървърите и рутерите са известни на хора, които нямат нужда от тях в ежедневната си работа. Това не е въпрос на доверие към конкретен човек — в сигурността правилото е просто: **парола, която знае някой, който не трябва, се счита за компрометирана**. Дори без лоши намерения — тя може да бъде записана, споделена или изтекла.

Смяната е бърза, безплатна и затваря най-широката врата. Затова е номер едно.

✓ ПОТВЪРДЕНО

КАКВО ПРАВИМ

- ☐ Опис на всички админ акаунти — сървъри, рутери, NAS, WiFi точки за достъп
- ☐ Нови, уникални и дълги пароли (16+ символа) — различна за всяко устройство
- ☐ Съхранение в криптиран мениджър на пароли (Password Manager), а не в тетрадка или Excel
- ☐ Контролна проверка, че старите пароли вече не отварят нищо

02**Край на администраторските права за всички**

РАБОТНИ СТАНЦИИ • СТАНДАРТНИ ПОТРЕБИТЕЛИ

ПРЕДСТОИ

ЗАЩО

Около 90% от компютрите работят с потребители с администраторски права. Това е **бомба със закъснител**. Когато вирус влезе на такава машина — от прикачен файл, фалшив линк или заражена флашка — той получава същите права като потребителя. Тоест пълни: може да изключи защитата, да се закачи дълбоко в системата и оттам да тръгне към останалите компютри и сървъра.

Със стандартен потребител (Standard User) същият вирус удря в стена: не може да инсталира, не може да пипа системата, щетите остават локални.

Честно казано: има модерен зловреден софтуер, който умее да си повишава правата (Privilege Escalation) и ограниченията не го спират напълно. Но разликата между „заразен е един компютър“ и „заразена е цялата мрежа“ често минава точно оттук.

✓ ПОТВЪРДЕНО

КАКВО ПРАВИМ

- ☐ Отделен сервизен админ акаунт на всяка машина — само за поддръжката
- ☐ Тест на работния ви софтуер под стандартен потребител, преди да сменя правата
- ☐ Преминаване на всички потребители към стандартни акаунти
- ☐ Ясна процедура: трябва ви програма — пишете ми и я слагам отдалечено

ЗАЩО

Днес до админ панелите на рутерите и сървърите може да се стигне директно от интернет. А интернет е пълен с ботове, които денонощно сканират адреси и чукат на всяка отворена страница за вход — пробват пароли и известни уязвимости. Видима отвън страница за вход е мишена, независимо колко е добра паролата.

Решението: **изключваме достъпа отвън** и изграждаме криптиран VPN тунел. Първо се влиза във VPN-а с личен акаунт — и чак тогава админ панелите изобщо стават видими. За външния свят вратата просто изчезва.

✓ ПОТВЪРДЕНО

КАКВО ПРАВИМ

- ☐ Изграждане на криптиран VPN тунел с индивидуални акаунти
- ☐ Изключване на достъпа от интернет (WAN) до админ панелите на рутерите
- ☐ Преглед и затваряне на излишните пренасочени портове (Port Forwarding) към сървърите
- ☐ Тест отвън: конзолите не се виждат, а през VPN работят нормално

ЗАЩО

Avast Free е безплатен продукт за домашна употреба. В среда с десетки устройства и сървъри на него не може да се разчита: няма централна конзола, няма как да видя на едно място кой компютър е защитен и кой не, няма политики и известия.

По-сериозният проблем: **сървърите в момента работят без никаква антивирусна защита**. Avast Free просто не се инсталира на сървърни операционни системи. А сървърът е сърцето — там са данните на всички.

Предлагам да минем на **Bitdefender GravityZone** — един от най-силните продукти в бранша, с една конзола за всички машини, включително сървърите.

✓ ПОТВЪРДЕНО

КАКВО ПРАВИМ

- ☐ Избор на пакет и срок — обсъждаме разликите заедно
- ☐ Покупка на 39 лиценза
- ☐ Премахване на Avast Free от всички машини
- ☐ Инсталиране на агента на Bitdefender — компютри и сървъри
- ☐ Централни политики, планирани сканирания и известия към мен

ЦЕНИ · 39 МАШИНИ · ЛИЦЕНЗ ЗА 1 ГОДИНА · БЕЗ ДДС

ПАКЕТ	СТАНДАРТНА ЦЕНА	ВАШАТА ЦЕНА	ОТСТЪПКА	39 МАШИНИ / МЕСЕЦ
Business Security ПРЕПОРЪЧВАМ ЗА СТАРТ	2,50 €	1,38 €	-45%	53,82 €
Business Security Premium	5,50 €	2,99 €	-46%	116,61 €

Цените са на машина на месец. При лиценз за **3 години** цената пада с още **10%**. Моята препоръка е да стартираме с Business Security — дава солидна основа. Ако по-късно преценим, че ни трябва по-тежка защита, минаваме на Premium. Разликите между двата пакета ще разгледаме заедно на среща.

ЗАЩО

Личните телефони, домашните лаптопи и устройствата на гостите са извън нашия контрол — не знаем какво има на тях и кога за последно са обновявани. Днес те са в същата мрежа като сървъра и работните компютри. Едно заразено устройство вътре е все едно сме му отворили вратата сами.

Решението е отделна гост мрежа: интернет — да, вътрешните ресурси — не. Хубавата новина — **настоящите точки за достъп го поддържат**, трябва само да се конфигурират. Нула разход.

✓ ПОТВЪРДЕНО

КАКВО ПРАВИМ

- ☐ Нова отделна мрежа (SSID) за гости и лични устройства
- ☐ Изолация: без достъп до сървъра, NAS-а и работните компютри
- ☐ Нова парола за вътрешната мрежа — иначе личните телефони, които я помнят, ще продължат да се закачат вътре
- ☐ Кратко съобщение до екипа: коя мрежа за какво е

Тези пет точки са с първостепенно значение и предлагам да ги изпълним с приоритет. След тях идва втори списък — по-прецизна работа по политиките за сигурност на сървърите, рутерите и работните станции. Ще го прилагам поетапно, без да спирам работата ви.

СЪРВЪРИ

Политики за сигурност и одит на достъпа

РУТЕРИ

Прецизни правила на защитната стена (Firewall)

РАБОТНИ СТАНЦИИ

Единни политики за всички компютри

МОНИТОРИНГ

Поетапно затягане и контрол на резултата

С УВАЖЕНИЕ

Атанас Иванов

Управител и главен компютърен специалист

НАСА РОБОТИКС ЕООД

IT ПОДДРЪЖКА И КИБЕРСИГУРНОСТ



0888 352 421



a.ivanov@nasa-robotics.com



www.nasa-robotics.com